

Azure Key Vault – Best Practices

1. Overview

Azure Key Vault is used to securely store and manage:

- Secrets
- Keys
- Certificates

Because Key Vault contains sensitive information, we should follow security best practices.

The most important Key Vault best practices are:

1. Enable Soft Delete
2. Enable Purge Protection
3. Follow RBAC and Least Privilege
4. Rotate Keys and Secrets regularly
5. Restrict network access
6. Use Microsoft Defender for Key Vault

2. Enable Soft Delete

Soft Delete should always be enabled.

When Soft Delete is enabled, a deleted Key or Secret is not immediately permanently deleted.

Instead:

```
Key/Secret
  ↓
Delete
  ↓
Soft Deleted
  ↓
Can be Recovered
```

Why is Soft Delete important?

It protects against:

- Accidental deletion

- Human mistakes
- Malicious deletion
- Incorrect scripts or automation

Example

Suppose someone accidentally deletes a database connection string.

With Soft Delete enabled:

```
SQL Connection String
  ↓
Deleted
  ↓
Soft Deleted
  ↓
Recover
```

We can recover the deleted Secret during the applicable retention period.

3. Enable Purge Protection

Purge Protection should also be enabled.

Purge Protection provides an additional layer of protection after an object has been soft deleted.

When Purge Protection is enabled, a soft-deleted Key or Secret cannot be permanently purged during the mandatory retention period.

Example

Suppose the retention period is 90 days:

```
Secret
  ↓
Delete
  ↓
Soft Deleted
  ↓
Purge Protection
  ↓
```

Cannot permanently delete
during the retention period

Easy way to remember

Soft Delete

- Protects against deletion
- Allows recovery

Purge Protection

- Protects against permanent deletion
- Blocks purge during retention period

Best Practice

For production Key Vaults:

Soft Delete → ENABLE
Purge Protection → ENABLE

4. Use RBAC and Least Privilege

Another important best practice is to follow the **Principle of Least Privilege**.

What is Least Privilege?

Give a user or service **only the permissions it actually needs**.

Do not give unnecessary access.

Example 1 – Application Only Needs Secrets

Suppose an application only needs to read Secrets.

We should not give the application access to:

- Keys
- Certificates
- Secret management operations it does not need

Instead, give it a role that provides only the required Secret permissions.

Conceptually:

```
Application
  ↓
Key Vault
  ↓
Read Secrets
```

Not:

```
Application
  ↓
Key Vault
  ├── Keys
  ├── Secrets
  ├── Certificates
  └── Full Administration
```

5. Read-Only Access

Suppose a user only needs to **read Secrets**.

We should give the user a read-only Secret-related role rather than a role that allows creating, updating, or deleting Secrets.

For example, Azure provides roles such as:

Key Vault Secrets User

This role is designed for scenarios where an identity needs to retrieve Secret values without giving it broad Key Vault management permissions.

Principle

```
Requirement:
Read Secrets
```

Permission:
Read Secrets only

Do not provide:

Full Key Vault access

unless it is actually required.

6. Why Least Privilege is Important

Suppose an application has excessive permissions.

If the application's identity is compromised, an attacker may gain access to more Key Vault resources than necessary.

Without Least Privilege

Compromised Application
↓
Key Vault
↓
Keys + Secrets + Certificates

With Least Privilege

Compromised Application
↓
Key Vault
↓
Only required Secret access

Therefore:

Give only the minimum permissions required to perform the task.

7. Rotate Keys and Secrets Regularly

Keys and Secrets should be rotated regularly.

Key Rotation

Create a new version of the Key before the existing version expires.

```
Key Version 1
  ↓
Create Version 2
  ↓
Latest Version
```

Secret Rotation

Replace sensitive credentials with new credentials and store the new value as a new Secret version.

Example:

```
Old Password
  ↓
Generate New Password
  ↓
Update Database
  ↓
Store New Connection String
  ↓
New Secret Version
```

Why Rotate?

Regular rotation helps:

- Reduce the lifetime of credentials
- Reduce security risks
- Meet security/compliance requirements
- Limit the impact if credentials are compromised

8. Restrict Network Access

If Key Vault does not need to be accessible from the public internet, we should restrict its network access.

Instead, allow access only from trusted networks such as an approved **Virtual Network (VNet)**.

Without Network Restriction

Internet
↓
Key Vault

This exposes the Key Vault endpoint to public network access, subject to its authentication and network controls.

With Network Restriction

Trusted VNet
↓
Key Vault

Public access can be restricted according to the organization's network architecture.

Main Idea

If public internet access is not required, restrict Key Vault access to trusted networks.

9. Use Microsoft Defender for Key Vault

Microsoft Defender for Cloud provides **Microsoft Defender for Key Vault**.

It helps detect unusual and potentially harmful activity involving Key Vault.

Examples include suspicious attempts to:

- Access Key Vault
- Retrieve sensitive information
- Exploit Key Vault resources

Simple Understanding

Think of Defender as an additional security monitoring layer:

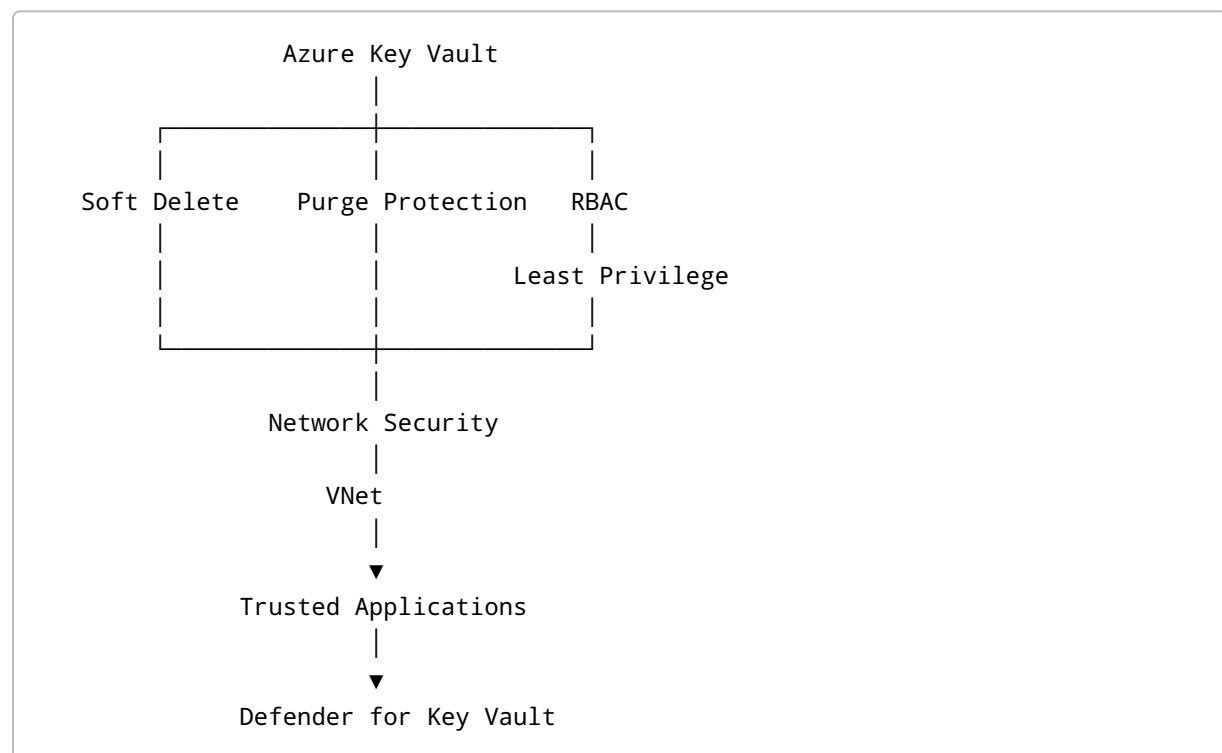
Users / Applications
↓
Key Vault
↓
Microsoft Defender

↓
Detect Suspicious Activity

It can help identify unusual access patterns and potential threats.

10. Complete Key Vault Security Model

A good production setup can look like this:



11. Key Vault Best Practices – Quick Table

Best Practice	Purpose
Enable Soft Delete	Recover accidentally deleted objects
Enable Purge Protection	Prevent permanent deletion during retention period
Use RBAC	Control access based on roles
Follow Least Privilege	Give only required permissions
Rotate Keys	Reduce cryptographic key exposure

Best Practice	Purpose
Rotate Secrets	Reduce credential exposure
Restrict Network Access	Reduce exposure to public internet
Use Defender for Key Vault	Detect suspicious activity

12. Interview Questions

Q1. What are the best practices for Azure Key Vault?

A good answer:

The main best practices are enabling Soft Delete and Purge Protection, following RBAC and Least Privilege, regularly rotating Keys and Secrets, restricting network access when public access is not required, and using Microsoft Defender for Key Vault for threat detection.

Q2. Why should we enable Soft Delete?

Soft Delete protects Key Vault objects from immediate permanent deletion and allows deleted objects to be recovered during the retention period.

Q3. Why should we enable Purge Protection?

Purge Protection prevents soft-deleted Key Vault objects from being permanently purged during the mandatory retention period, providing an additional layer of protection against accidental or malicious deletion.

Q4. What is the Principle of Least Privilege?

It means giving a user, application, or service only the minimum permissions required to perform its task.

Q5. Why should we use RBAC in Key Vault?

RBAC allows us to control access to Key Vault resources through Azure roles and assign only the permissions required by users or applications.

Q6. Why should Keys and Secrets be rotated?

Regular rotation reduces the lifetime of credentials and cryptographic keys and limits the potential impact if they are compromised.

Q7. How can we restrict access to Key Vault?

We can use Key Vault networking controls to restrict access and, when appropriate, allow access only from trusted networks such as a VNet rather than the public internet.

Q8. What is Microsoft Defender for Key Vault?

Microsoft Defender for Key Vault is a security monitoring capability that helps detect unusual and potentially malicious activity involving Key Vault.

13. Easy Way to Remember

Remember these **6 Key Vault Best Practices**:

1. BACKUP
 - Soft Delete + Purge Protection
2. CONTROL
 - RBAC + Least Privilege
3. ROTATE
 - Keys + Secrets
4. RESTRICT
 - Network Access
5. MONITOR
 - Defender for Key Vault
6. PROTECT
 - Never give unnecessary permissions

One-Line Interview Answer

"For Azure Key Vault, we should enable Soft Delete and Purge Protection, follow RBAC and Least Privilege, regularly rotate Keys and Secrets, restrict network access where possible, and use Microsoft Defender for Key Vault to detect suspicious activity."